Risk Assessment

“identify, estimate and prioritize risk to organizational operations”

NIST 800-30

- **Threats** to an organization
- **Vulnerabilities** inside organizations
- **Adverse impact** which would occur when a threat exploits a vulnerability
- **Likelihood** that the impact will occur

Why are Risk Assessments Needed?

Support a variety of risk-based decisions

- **Design of security solutions** for information systems
- Determining **who should be authorized** to operate systems
- **Modification of business functions** to avoid a vulnerability
  - Change the webpage to eliminate an attack vector
- Evaluating the **utility of specific information technology products**
  - A product may introduce a vulnerability

Risk Assessment vs. Penetration Testing

- Risk Assessment is primarily for management
  - Set policies, determine how to spend money
  - Technical details are less relevant to the audience
- Penetration Testing
  - Test and highlight vulnerabilities in security posture
  - Lot’s of technical detail
  - Not necessarily tied to business needs
  - May inform a risk assessment

Risk Assessment Standards

- Several standards exist, similar processes

National Institute of Standards and Technology (NIST)

Guide for Conducting Risk Assessments

- NIST Special Publication 800-30
  - Commonly used standard in the US
  - Very, very thorough
  - Overkill for most companies/domains
  - Pick and choose what is useful in your context

What is Risk?

- A measure of the extent to which an entity is threatened by a potential event

A function of:

- Adverse impact if an event occurred
- Likelihood that the event will occur
- Simple approximation: **risk = impact * likelihood**
- Also a function of my vulnerabilities

Parts of a Risk Assessment Methodology

- **Risk Model** – Defining risk factors and relationships among the factors
  - Well-defined threats, vulns, impacts are needed to assess risk
- **Assessment Approach** – Choose a granularity which will be used to measure risk
  - Continuous vs. discrete, how many buckets?
- **Analysis Approach** – Choose a perspective from which to consider the risks
  - Threat-oriented, vulnerability-oriented, asset-oriented
  - Often use multiple approaches
- **Risk Assessment Process** – Decide on specific steps to perform the assessment
  - Prepare source information, identify threat sources, identify vulnerabilities, etc.

Risk Models

- Define the risk factors specific to your organization
- What you need to assess

Threats – Who/what may attack your organization?

Vulnerabilities and Predisposing Conditions – What weaknesses does your organization have?

Likelihood – Probability that a given threat can exploit a given vulnerability.

Impact – What are the effects of a successful attack on assets

Risk - impact * likelihood

Aggregation – Grouping risks into risk classes. Helpful for communication.

Uncertainty – Must consider the error in your risk estimates

Threats

- **Threat event** - Any event that can hurt your organization
- **Threat sources** – Individuals, groups, or circumstances which may cause threat events
- Need to enumerate all threat events and threat sources for your system
- Specific threat sources can only cause a subset of threat events
  - A system user cannot cause an earthquake

Example Threats

City Water Facility

Event: Dump stored water

Source: Enemy nation (i.e. Sandworm)

Event: Falsify billing information

Source: Individual water consumers

Power Company

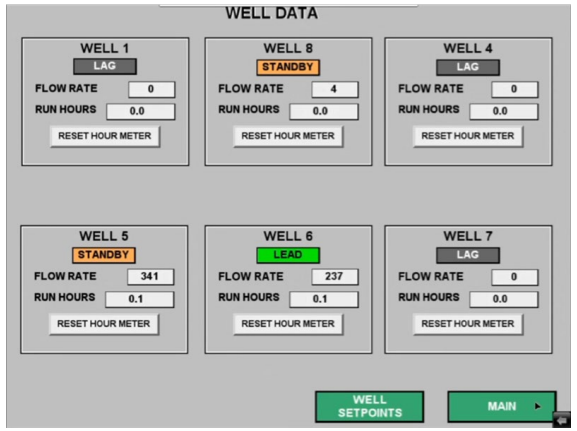
Event: Synchronized activation of AC

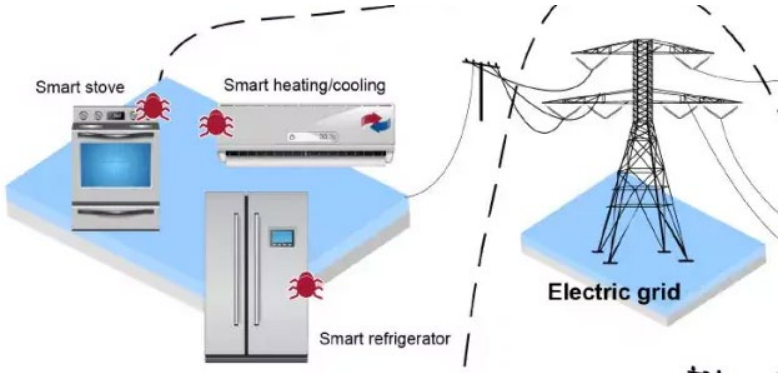
Source: Organized Crime

Hospital

Event: Encryption of all data

Source: Organized crime





Vulnerabilities and Predisposing Conditions

- Weakness in your system which could be exploited by a threat source
  - An important security control is not applied
  - Old security controls are no longer effective
- Not restricted to information systems
  - Recovery process not well defined
  - Bad communication between groups
- External relationships may have vulnerabilities
  - Cloud provider
  - Third-party component not secure

Likelihood

- Combination of properties of adversaries
  - Intent
  - Capability
  - Targeting
- Examples

1. Kill me by controlling my Tesla
2. Steal data from a computer in my house
3. Steal data from a computer in my neighbor’s house

Impact

- How expensive would a successful attack be?
- Depends on the asset which is compromised

1. Credit card customer data – massive identity theft, loss of trust/customers
2. Hospital records – postponed treatments, loss of life
3. Proprietary intellectual property – loss of ability to compete
4. Online service goes down – Customer anger, loss of customers

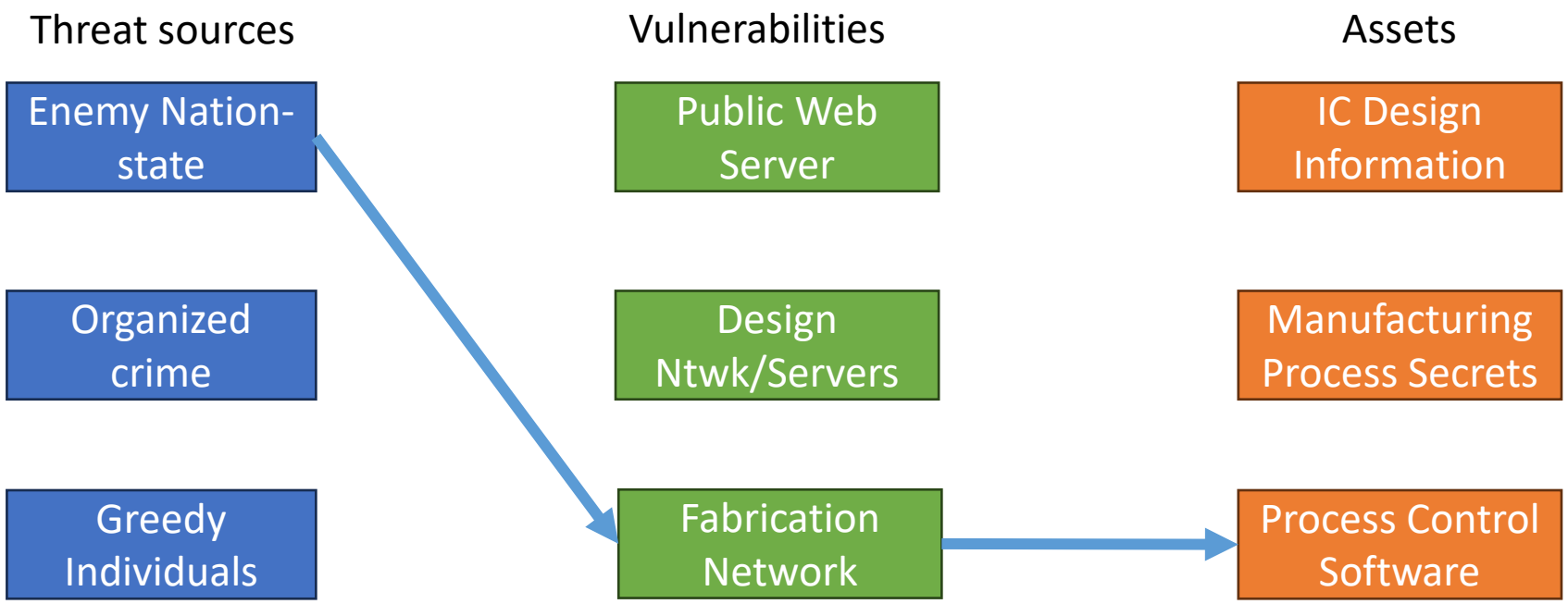
Aggregation and Uncertainty

- **Aggregation** - Considering the impact of multiple concurrent attacks
  - Earthquake and Tsunami at Fukuoka Nuclear Power Plant
  - This is pretty advanced
- **Uncertainty** – Never have complete information
  - 0-day attacks
  - May try to express your uncertainty

Assessment Approaches

- What scale will be used for each measure?
  - 1-10
  - Red, yellow, green
  - Low, medium, high
- Provide a rubric defining the meaning of each ranking
- Must provide prose description as well
  - Simple ranking is not enough

Threats, Assets, Vulnerabilities



- Threats involve sources reaching assets through vulnerabilities

Analysis Approaches

- How will you enumerate all risks?
- Threats, assets, vulnerabilities
- **Threat-oriented**
  - Enumerate all threats and consider their impact on your system
  - NIST 800-30 has a pretty thorough list, and there are other sources
- **Asset/Impact-oriented**
  - Enumerate all assets and consider everything that could happen to them
  - Can limit assessment to important assets for the business
- **Vulnerability-oriented**
  - Enumerate known vulnerabilities and think about what threats can exploit them and what assets can be disturbed by them

Taxonomy of Threat Sources

- NIST 800-30 provides a taxonomy of threat sources
  - Table D-3
- Items in this taxonomy must be made specific for an organization

Top level

Adversarial - Individuals, groups, organizations, or states that seek to exploit the organization's dependence on cyber resources.

Accidental - Erroneous actions taken by individuals in the course of executing their everyday responsibilities.

Structural - Failures of equipment, environmental controls, or software due to aging, resource depletion, or other circumstances which exceed expected operating parameters.

Environmental - Natural disasters which are outside the control of the organization.

Adversarial Threat Sources

- Threat sources are distinguished by their ability to do harm
  - What information do they have access to?
  - What resources can they use to attack?
- These should be enumerated for an organization
- Enumeration is not realistic for some classes
  - Individuals

- Individual
  - Outsider
  - Insider
  - Trusted Insider
  - Privileged Insider
- Group
  - Ad hoc
  - Established
- Organization
  - Competitor
  - Supplier
  - Partner
  - Customer
- Nation-State

Taxonomy of Threat Events

- NIST 800-30 provides a taxonomy of threat events
  - Appendix E, Table E-2
- There are many possible events in the taxonomy
- The taxonomy must be pruned to match events which are possible for specific organizations

Top-Level Taxonomy of Threat Events

- **Perform reconnaissance and gather information** – Surveillance from outside
- **Craft or create attack tools** – Create things outside the system to perform attacks
- **Deliver/insert/install malicious capabilities** – Inject something into the system
- **Exploit and compromise** – Exploit known vulnerabilities
- **Conduct an attack** – Launch network attacks from outside
- **Achieve results** – Steal important data or destroy functionalities
- **Maintain a presence or set of capabilities** – Advanced Persistent Threat
- **Coordinate a campaign** – Bring large-scale capabilities to bear in an attack

Threat Events - Perform Reconnaissance

Reconnaissance Threat Events	Description
Perform perimeter network reconnaissance/scanning	Adversary uses commercial or free software to scan organizational perimeters to obtain a better understanding of the information technology infrastructure and improve the ability to launch successful attacks.
Perform network sniffing of exposed networks.	Adversary with access to exposed wired or wireless data channels used to transmit information, uses network sniffing to identify components, resources, and protections.
Gather information using open source discovery of organizational information.	Adversary mines publicly accessible information to gather information about organizational information systems, business processes, users or personnel, or external relationships that the adversary can subsequently employ in support of an attack.
Perform reconnaissance and surveillance of targeted organizations.	Adversary uses various means (e.g., scanning, physical observation) over time to examine and assess organizations and ascertain points of vulnerability.
Perform malware-directed internal reconnaissance.	Adversary uses malware installed inside the organizational perimeter to identify targets of opportunity. Because the scanning, probing, or observation does not cross the perimeter, it is not detected by externally placed intrusion detection systems.

Specifying Reconnaissance Threat Events

Reconnaissance Threat Events	Specific Information
Perform perimeter network reconnaissance/scanning	What networks are accessible at the perimeter?
Perform network sniffing of exposed networks.	What data channels (wired or wireless) are exposed to sniffing?
Gather information using open source discovery of organizational information.	What organizational information is public (i.e. on a webpage, social media, etc.)?
Perform reconnaissance and surveillance of targeted organizations.	What are the physical access points? What rooms can be entered, seen, or heard?
Perform malware-directed internal reconnaissance.	What networks are internal?

Threat Events – Craft or Create Attack Tools

Attack Tool Threat Events	Description
Craft phishing attacks.	Adversary counterfeits communications from a legitimate/trustworthy source to acquire sensitive information such as usernames, passwords, or SSNs.
Craft spear phishing attacks.	Adversary employs phishing attacks targeted at high value targets (e.g., senior leaders/executives).
Craft attacks specifically based on deployed information technology environment.	Adversary develops attacks (e.g., crafts targeted malware) that take advantage of adversary knowledge of the organizational information technology environment.
Create counterfeit/spoof website.	Adversary creates duplicates of legitimate websites; the site can gather information or download malware.
Craft counterfeit certificates.	Adversary counterfeits or compromises a certificate authority, so that malware or connections will appear legitimate.
Create and operate false front organizations to inject malicious components into the supply chain.	Adversary creates false front organizations with the appearance of legitimate suppliers.

Specifying Attack Tool Threat Events

Attack Tool Threat Events	Specific Information
Craft phishing attacks.	What organizational information is possessed by each employee?
Craft spear phishing attacks.	Who has critical information? What information do they have?
Craft attacks specifically based on deployed information technology environment.	Who knows details of infrastructure? What do they know?
Create counterfeit/spoof website.	What organizational information is possessed by each employee? What (sub)network contains their devices?
Craft counterfeit certificates.	What certificate authorities do your machines use?
Create and operate false front organizations to inject malicious components into the supply chain.	Who are your suppliers? How have you authenticated them?

Multitiered Risk Management

- Organizations often solve a problem with looking at the big picture
- Example – **Ransomware attack on a hospital**
  - Attackers have encrypted all data. Will not unencrypt it without payment.
  - Solution 1 – Reconstitute data from backups
  - Solution 2 – Solution 1 + check/update all machines
  - Solution 3 – Solution 2 + define a process for regularly checking machines
  - Solution 4 – Solution 3 + assign money/personnel to ransomware prevention
- Risk management must be **integrated throughout the organization**

Tiers of Risk Management

Tier 1 – Organization

- Define mission/business functions and their (budget) priorities
- Identify critical functions and assets

Tier 2 – Mission/business Processes

- Define processes to accomplish mission/business functions
- Incorporate security requirements into processes

Tier 3 – Information Systems

- Directly protecting organizational information systems
- Choosing and using security tools

Risk Assessment at each Tier

- Risk assessments usually include recommendations
- Recommendations can be targeted at different tiers
- Rec. 1 – Hire an outside firm to handle cybersecurity
  - Tier 1
- Rec. 2 – Develop a process for tracking computer inventory
  - Tier 2
- Rec 3. – Use a tool for automatic software patching
  - Tier 3